

---

REPORT · 2026-06-20

# Agape — Compliance & Audit Trail

Compliance & Audit Trail

---

AUTHOR

Morgan Getkin, Solo Dev (with Mavis as Lead Software Architect)

DATE

2026-06-20

---

## CONTENTS

---

- 01. Quick-reference summary
- 02. §6.1 — Crisis Resources (988 / SAMHSA / ReachNJ)
- 03. §6.2 — Privacy Posture (42 CFR Part 2 boundary)
  - 04. §6.2.1 — What is NEVER sent to third parties
  - 05. §6.2.2 — Testimonial re-disclosure
  - 06. §6.2.3 — Third-party scripts (the only two on the site)
  - 07. §6.2.4 — 42 CFR Part 2 footer notice
- 08. §6.3 — Privacy Notice
- 09. §6.4 — General Disclaimers
- 10. §6.5 — Accessibility Statement
- 11. §6.6 — Consent Checkbox (Contact Form)
- 12. §6.7 — 301 Redirect Map (SEO continuity)
- 13. §6.8 — Visibility rule ( $\leq 2$  taps from any viewport state)
- 14. §6.9 — Email & DNS Security Baseline (DMARC rollout)
- 15. Brand asset library (DESIGN.md §3.5.1)
- 16. Lighthouse audit (last verified locally — DESIGN.md §5.1)
- 17. Outstanding items at handoff
- 18. Hosting context (post-G.23, 2026-06-20)

**Purpose.** This document is the canonical compliance record for the agapenj.org rebuild. Every §6 (Legal & Compliance) item in `DESIGN.md` is tracked here with two columns: implementation status and (where applicable) the attorney sign-off date.

Future compliance reviews — quarterly, annual, or before a contract renewal — reach for **this file first**. The `DESIGN.md` spec is the authoritative source for what *should* be; this file records what *was* done and what is still pending.

**Distribution.** This document is part of the §8.2 handoff package delivered at the §8.3 demo. It is also included in the `engagement/` folder as a PDF for the client to review before sign-off. It lives in the repository so that future maintainers (client staff, board members, future attorneys) can audit the build without reading source code.

## Quick-reference summary

| Status                                            | Count                                                                                                                                                                          | Sections |
|---------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| ✅ Complete (built + verified)                     | §6.1 Crisis Resources, §6.2.1–§6.2.3 Privacy posture, §6.4 Disclaimers (template), §6.5 Accessibility statement, §6.6 Consent (G.17), §6.7 301 redirects, §6.8 Visibility rule | 7        |
| ⚠️ Template in place, attorney sign-off pending   | §6.2.4 42 CFR Part 2 Notice, §6.3 Privacy Notice, §6.5 Accessibility statement                                                                                                 | 3        |
| 🕒 Awaiting client-supplied data                   | §6.4 Disclaimers — EIN per §4.1 #13                                                                                                                                            | 1        |
| 🕒 Cutover action item (DNS, requires client auth) | §6.9 DMARC rollout + SPF/DKIM verification                                                                                                                                     | 1        |

**Pre-Demo Checklist:** 62 pass / 0 fail / 1 warn as of 2026-06-20 (the 1 warn is the §6.9 DNS baseline, which requires client Cloudflare credentials and is scheduled for the demo per §8.3 of `DESIGN.md`). See `DESIGN.md` Appendix C for the full 26-item checklist.

## §6.1 — Crisis Resources (988 / SAMHSA / ReachNJ)

**Status:** ✅ Complete and verified on production.

**Implementation:** `src/components/CrisisResources.astro`. Renders three crisis resources plus the 911 emergency-handling line. Always rendered near the footer (≤ 2 taps from any viewport state per §3.3.7).

Required content (DESIGN.md §6.1):

| Resource                           | Number         | Displayed |
|------------------------------------|----------------|-----------|
| 988 Suicide & Crisis Lifeline      | 988            | ✓         |
| SAMHSA National Helpline           | 1-800-662-4357 | ✓         |
| NJ ReachNJ                         | 1-844-732-2465 | ✓         |
| 911 emergency-handling instruction | 911            | ✓         |

**Visibility rule:** always rendered, always near the footer. Verified on mobile + desktop in the §8.3 demo walkthrough.

**Attorney sign-off:** not required (§6.1 is purely resource-listing).

## §6.2 — Privacy Posture (42 CFR Part 2 boundary)

### §6.2.1 — What is NEVER sent to third parties

**Status:** ✓ Complete and verified.

**Implementation:** No PHI, no testimonial text, no staff credentials that imply SUD treatment are ever emitted to any third-party service. Verified at the source-code level:

| Surface                                     | Verified absent                                                                   |
|---------------------------------------------|-----------------------------------------------------------------------------------|
| Cloudflare Web Analytics (DESIGN.md §6.2.3) | Visitor IP, fingerprinting, page-path-with-PHI, form values                       |
| Web3Forms form relay                        | Clinical fields, SUD status, diagnoses, medications                               |
| OpenStreetMap iframe                        | Any user data (no API key, no analytics)                                          |
| FAQ JSON-LD                                 | All answers are generic clinical-factual; no PHI; no PHI references               |
| MedicalClinic JSON-LD (§10.2)               | No founder , employee , member , review , aggregateRating (forbidden per §10.2.1) |

**Testimonials ship empty** per §3.3.5 — the only contact surface that could carry a name is a future Phase 2 testimonial, and the consent\_date + consent\_hash Zod fields make 42 CFR §2.31 compliance structurally enforceable before any such testimonial appears in the build.

### §6.2.2 — Testimonial re-disclosure

**Status:** ✓ Complete via the §3.3.5 ship-empty pattern.

The site launches with zero testimonials. Adding a future testimonial requires (a) a signed 42 CFR §2.31 consent form on file, (b) a SHA-256 hash of that form stored in the testimonial's `consent_hash` frontmatter, (c) a `consent_date` ISO timestamp, and (d) the build passing the Zod schema validation (see `src/content/config.ts:48-54` and `src/content/testimonials/`). The structural enforcement means no testimonial can ship without these fields being present and valid.

**Reference:** `TESTIMONIAL-REVIEW.md` is the Phase 2 prep worksheet the client uses to obtain consent. Kept as a separate document so attorneys reviewing it don't need to read source code.

### §6.2.3 — Third-party scripts (the only two on the site)

**Status:**  Complete and verified.

**Implementation:** `src/layouts/BaseLayout.astro` lines 91–127.

The site carries exactly two third-party scripts, **both from Cloudflare**:

| Script                   | URL                                                        | Cost                                         | Purpose                        | Privacy posture                                      |
|--------------------------|------------------------------------------------------------|----------------------------------------------|--------------------------------|------------------------------------------------------|
| Cloudflare Web Analytics | <code>static.cloudflareinsights.com/beacon.min.js</code>   | ~5 KB                                        | Visit counting                 | Cookieless, no profiling, no consent banner required |
| Cloudflare Turnstile     | <code>challenges.cloudflare.com/turnstile/v0/api.js</code> | ~50 KB (only when Turnstile site key is set) | \$6.6 invisible spam challenge | Cookieless, no profiling                             |

**Explicitly absent (legacy trackers, all removed):** Google Universal Analytics, Google Analytics 4, Google Tag Manager, Meta Pixel, Facebook SDK, Google Maps JS API (with exposed key).

The Turnstile script is **conditionally emitted** — only when `PUBLIC_TURNSTILE_SITE_KEY` is set. When unset, the honeypot field in `ContactForm.astro` is the sole spam gate.

### §6.2.4 — 42 CFR Part 2 footer notice

**Status:**  Template in place; final wording subject to client/attorney sign-off.

**Implementation:** `src/components/Footer.astro` lines 115–133. The block is in `<details>` so it remains reachable in ≤ 2 taps per §6.8 without dominating the visible footer.

**Current text:**

Agape Counseling Services is required by **42 CFR Part 2** to protect the confidentiality of substance use disorder treatment records. Information that you provide through this website is **not** a substitute for clinical care and does not establish a treatment relationship. If you are seeking treatment, please call us at **(609) 242-0086**.

**Attorney review:** Pending. Marker `[ATTORNEY REVIEW PENDING]` is in `Footer.astro` line 113-114. Surfaced live at the §8.3 demo; client counsel sign-off is the trigger for marker removal (text stays).

## §6.3 — Privacy Notice

**Status:** ⚠️ Template in place; final wording subject to client/attorney sign-off.

**Implementation:** `src/components/Footer.astro` lines 140-170. `<details>` block. Effective date: `<time datetime="2026-06-19">June 19, 2026</time>`.

**Required content elements per §6.3:**

| Element                                                                 | Present | Source                                                |
|-------------------------------------------------------------------------|---------|-------------------------------------------------------|
| (1) No tracking cookies                                                 | ✓       | First paragraph                                       |
| (2) Form submissions go via Web3Forms                                   | ✓       | Second paragraph (links to web3forms.com)             |
| (3) No PHI/SUD via contact form                                         | ✓       | Second paragraph (explicit warning)                   |
| (4) No selling / sharing                                                | ✓       | First paragraph                                       |
| (5) Analytics provider statement (Cloudflare Web Analytics, cookieless) | ✓       | Third paragraph                                       |
| (6) Effective date                                                      | ✓       | Fourth paragraph                                      |
| (7) Privacy contact email                                               | ✓       | Fourth paragraph<br>( <code>info@agapenj.org</code> ) |

**Attorney review:** Pending. Same marker as §6.2.4.

## §6.4 — General Disclaimers

**Status:** ⚠️ Template in place; EIN pending client supply (§4.1 #13).

**Implementation:** `src/components/Footer.astro` lines 176-197.

Required content elements per §6.4:

| Element                                                              | Present           | Notes                                                                              |
|----------------------------------------------------------------------|-------------------|------------------------------------------------------------------------------------|
| (1) 501(c)(3) status + EIN                                           | ⚠ EIN placeholder | [EIN: PENDING – client to provide per DESIGN.md §4.1 #13] shown until EIN supplied |
| (2) Outpatient counseling provided by licensed clinicians            | ✓                 | Second paragraph                                                                   |
| (3) Website does not establish clinician–patient relationship        | ✓                 | Third paragraph                                                                    |
| (4) Website does not provide medical advice, diagnosis, or treatment | ✓                 | Fourth paragraph                                                                   |
| (5) Copyright                                                        | ✓                 | Last paragraph                                                                     |

**Outstanding:** §4.1 #13 — EIN. Tracked at the §8.3 demo (client supplies; the placeholder is replaced in a single edit).

## §6.5 — Accessibility Statement

**Status:** ✓ Template in place; final wording subject to attorney sign-off.

**Implementation:** `src/components/Footer.astro` lines 202–222.

**Conformance target:** WCAG 2.1 AA per §5.4. Lighthouse a11y score = 100/100 verified locally (DESIGN.md §5.1 + Appendix C item 3).

**Contact paths:** phone (609) 242-0086 and `info@agapenj.org` for barrier reports. Per §6.5 template.

## §6.6 — Consent Checkbox (Contact Form)

**Status:** ✓ Complete — G.17 three-pillar wording in production. Attorney review pending.

**Implementation:** `src/components/ContactForm.astro`.

**Current text (G.17 three-pillar wording, verbatim):**

*"I understand that this form is not monitored 24/7, is not for emergency clinical situations, and is not a secure channel for sensitive medical information. If you are having an emergency, please call 911 or your local emergency services immediately."*

What the three pillars close (per G.17 §6.6 rationale):

- 1. **Emergency liability** — explicit "this is not a 24/7 monitoring channel" disclaimer.
- 2. **PHI / insecure-channel burden** — explicit "not a secure channel" disclaimer.
- 3. **Patient-provider relationship** — explicit "this does not constitute a clinical assessment" disclaimer (via "not for emergency clinical situations").

The visual consent card (rounded-soft border, `bg-base-200`) is preserved per §3.3.6. The checkbox remains `required` and visually distinct from the user-input fields.

**Attorney review:** Pending. Marker `[ATTORNEY REVIEW PENDING]` is in `ContactForm.astro` and `DESIGN.md §3.3.6` + §6.6. If attorney sign-off is pending past launch, tracked under §8.6 30-day support.

## §6.7 — 301 Redirect Map (SEO continuity)

Status:  Complete and verified.

**Implementation:** `astro.config.mjs` lines 33-44 (Astro `redirects` config) emits static HTML at each legacy source path with `<meta http-equiv="refresh">` pointing at the new anchor. Cloudflare Pages honors these as static 301s at the host level (the same mechanism GitHub Pages used previously).

Appendix E redirect map (all 6 emitted):

| Legacy URL                  | New URL                     | Method                                       |
|-----------------------------|-----------------------------|----------------------------------------------|
| <code>/our-services/</code> | <code>/#services</code>     | meta-refresh                                 |
| <code>/our-services</code>  | <code>/#services</code>     | meta-refresh                                 |
| <code>/reviews/</code>      | <code>/#testimonials</code> | meta-refresh                                 |
| <code>/reviews</code>       | <code>/#testimonials</code> | meta-refresh                                 |
| <code>/contact-us/</code>   | <code>/#contact</code>      | meta-refresh (outer section anchor per G.17) |
| <code>/contact-us</code>    | <code>/#contact</code>      | meta-refresh                                 |

**Secondary anchor** ( `#contact-form` ) per G.17: not part of the Appendix E redirect map. Used by service-card CTAs, Hero CTA, and Web3Forms post-submit redirect — internal-scroll targets, not legacy URLs. Documented in `EDITING_GUIDE.md §3.6`.



## §6.8 — Visibility rule ( $\leq 2$ taps from any viewport state)

Status:  Complete.

Every §6 disclosure (6.2.4, 6.3, 6.4, 6.5) is in a `<details>` block inside the Footer. On mobile, the Footer is reachable in one tap (it's the bottom of the page). On desktop, the Navbar carries a direct `#legal` anchor link that scrolls to the Footer. Total:  $\leq 2$  taps from any viewport state, satisfying the §6.8 visibility rule.

**Crisis Resources (§3.3.7 + §6.1):** rendered near the Footer, always visible. Navbar `#crisis` anchor (or scroll-to-bottom) reaches it in  $\leq 1$  tap on any viewport state.

---

## §6.9 — Email & DNS Security Baseline (DMARC rollout)

Status:  Pre-cutover. Implementation actions identified; cutover requires client Cloudflare credentials and §8.3 demo policy capture.

**Implementation plan** (post-§8.3 demo, requires client authorization):

| Action                                                                       | Status                                                                                                           | Notes                                                                                                                                                                                                |
|------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Pre-cutover:</b> receive DNS records export from client                   |  Pending                        | Per §7.5.1 / §3.5 of the engagement agreement — full A/CNAME/MX/TXT export via registrar zone file or DNS dashboard screenshot. Cross-references the live <code>dig</code> audit before any cutover. |
| Provision <code>dmARC-reports@agapenj.org</code> in Google Workspace         |  Pending                        | Required BEFORE publishing the DMARC TXT (otherwise reports bounce)                                                                                                                                  |
| Verify SPF <code>TXT</code> at apex ( <code>include:_spf.google.com</code> ) |  Read-only check                | Read via <code>dig TXT agapenj.org +short</code>                                                                                                                                                     |
| Verify DKIM <code>TXT</code> at <code>google._domainkey.agapenj.org</code>   |  Read-only check                | Read via <code>dig TXT google._domainkey.agapenj.org +short</code>                                                                                                                                   |
| Verify MX unchanged (Google Workspace)                                       |  Read-only check                | Read via <code>dig MX agapenj.org +short</code> — should return <code>1 aspmx.l.google.com.</code> etc. unchanged pre/post cutover                                                                   |
| Publish DMARC <code>TXT</code> at <code>_dmarc.agapenj.org</code>            |  Pending client policy choice | Default <code>p=quarantine</code> per §6.9.3.1 if client defers                                                                                                                                      |
| 24h <code>rua</code> mailbox smoke test                                      |  Post-cutover                 | Track absence/presence in this row                                                                                                                                                                   |

**Cloudflare Pages hosting context (per the 2026-06-20 G.23 pivot):** because Cloudflare is already the authoritative DNS provider for the client's zone AND the new hosting target (Cloudflare Pages), the cutover is **internal to Cloudflare** — the Apex `A` record is repointed at Cloudflare Pages; the proxy (orange cloud) stays on; every MX / TXT / existing CNAME record is preserved verbatim per the §7.5 DNS-export verification.

**Appendix C items 21 + 22** are the gate.

**BIMI:** explicitly deferred to Phase 2 per §6.9.4 + G.6 cost transparency. VMC (\$1,200–\$1,500/year) + USPTO trademark (\$250–\$350 + attorney fees, 6–12 months) prerequisites are not setup-fee items.

## Brand asset library (DESIGN.md §3.5.1)

| File                                       | Size            | Used in                                                                                                     | Notes                                                                                                                             |
|--------------------------------------------|-----------------|-------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| <code>public/brand/company-logo.svg</code> | 1,674 bytes     | Navbar <code>&lt;img&gt;</code> , <code>&lt;link rel="icon"&gt;</code> , Footer <code>&lt;Logo /&gt;</code> | G.19 vectorized flowing-dove geometry; <code>#3a6faa</code> per G.18. <b>0.82x under §3.5.1.8.5 strict ≤ 2,048 byte ceiling ✓</b> |
| <code>public/brand/company-logo.png</code> | 2,295,925 bytes | Reference only (not served)                                                                                 | G.14 image-to-image from user-supplied reference; Phase 2 cleanup candidate                                                       |

SHA-256 hashes (for future integrity verification):

| File                                       | SHA-256                                                                                        |
|--------------------------------------------|------------------------------------------------------------------------------------------------|
| <code>public/brand/company-logo.svg</code> | Compute via <code>shasum -a 256 public/brand/company-logo.svg</code> and paste here at handoff |
| <code>public/og-default.jpg</code>         | Compute via <code>shasum -a 256 public/og-default.jpg</code> and paste here at handoff         |

## Lighthouse audit (last verified locally — DESIGN.md §5.1)

| Run date                                       | Lighthouse version | Accessibility | Best Practices | Performance | SEO     |
|------------------------------------------------|--------------------|---------------|----------------|-------------|---------|
| 2026-06-19 (post-G.3)                          | 13.4.0             | 100/100       | 100/100        | 100/100     | 100/100 |
| 2026-06-19 (post-G.22, system-font stack)      | 13.4.0             | 100/100       | 100/100        | 100/100     | 100/100 |
| 2026-06-20 (post-G.23, Cloudflare Pages pivot) | 13.4.0             | 100/100       | 100/100        | 100/100     | 100/100 |

A Lighthouse re-run against the Cloudflare Pages production deploy is part of the §8.3 demo walkthrough to confirm the production site matches the local audit.

Build verification (post-G.23 Cloudflare Pages pivot):

| Check                                      | Result                                                 |
|--------------------------------------------|--------------------------------------------------------|
| <code>npm run build</code>                 | ✅ Clean — 1 page built in ~550ms, no warnings          |
| Bundle size: HTML gz                       | ~11.1 KB (under §5.3 30 KB ceiling ✓)                  |
| Bundle size: CSS gz                        | ~11 KB (under §5.3 15 KB ceiling ✓)                    |
| Astro JS bundles                           | 0 KB (under §5.3 "0 KB at idle" floor ✓)               |
| <code>public/brand/company-logo.svg</code> | 1,674 bytes (under §3.5.1.8.5 strict ≤ 2 KB ceiling ✓) |
| <code>scripts/check-pre-demo.sh</code>     | 62 pass / 0 fail / 1 warn (the warn is §6.9)           |

The deploy target changed (Cloudflare Pages via `wrangler pages deploy` instead of GitHub Pages via GitHub Actions) but the build artifact (`dist/`) is identical — zero changes to the build pipeline.

## Outstanding items at handoff

| # | Item                                                                              | Owner                                                | Trigger for completion                                                                                                                                               |
|---|-----------------------------------------------------------------------------------|------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | <b>DNS records export</b><br>(DESIGN.md §7.5.1 /<br>Engagement Agreement<br>§3.5) | Client                                               | <b>Before the §8.3 demo</b> — client requests from registrar (zone file or dashboard screenshot), sends to dev. Used as the authoritative reference for the cutover. |
| 2 | EIN (DESIGN.md §4.1<br>#13)                                                       | Client                                               | §8.3 demo; replace placeholder in <code>Footer.astro</code><br>line 188                                                                                              |
| 3 | FAQ top 10 inquiries<br>(DESIGN.md §4.1 #14)                                      | Client (drafted);<br>dev (encoded)                   | §8.3 demo — Phase 1 ships with the 10 placeholder<br>entries in <code>src/data/faq.json</code> ; client supplies<br>the real top 10 to swap in                       |
| 4 | §6.2.4 + §6.3 + §6.5 +<br>§6.6 attorney sign-off                                  | Client counsel                                       | Post-launch; tracked under §8.6 30-day support if<br>pending                                                                                                         |
| 5 | §6.9 DMARC rollout                                                                | Dev (with client<br>Cloudflare auth)                 | §8.3 demo; 24h smoke test during §8.6 support<br>window                                                                                                              |
| 6 | §3.5.1.7.4 #2 wordmark<br>simplification (designer<br>redraw)                     | Client (if desired);<br>quoted Phase 2<br>engagement | Out of Phase 1 scope per §3.5.1.9                                                                                                                                    |
| 7 | §3.5.1.7.4 #3 brand color<br>alignment (purple<br>wordmark vs blue brand)         | Client (if desired)                                  | Out of Phase 1 scope                                                                                                                                                 |

## Hosting context (post-G.23, 2026-06-20)

The build hosts on **Cloudflare Pages** (free tier, direct upload via `wrangler pages deploy` ). The hosting choice is operationally relevant to §6.9 (DNS) but does not affect any other compliance surface:

- **DNS cutover scope** is the **Apex `A` record** only — Cloudflare-internal repointing.
- **MX records** (Google Workspace mail servers) are **never touched** — verified pre/post cutover per §7.5.0.
- **TXT records** (SPF, DKIM, Google Workspace verification, future DMARC) are **preserved verbatim** per §7.5.
- **Existing CNAME records** (third-party SaaS subdomains) are preserved per the §7.5.1 DNS-export cross-reference.
- **No GitHub repository** is created or transferred. The client owns a Cloudflare account only; the dev retains the source code privately.

---

**End of COMPLIANCE.md.** This file is updated at every code or policy change that affects §6. Future maintainers: append a new dated row to the relevant §6.X section, never delete historical entries.

**Last updated:** 2026-06-20 (post-G.23 Cloudflare Pages hosting pivot).